MK FRAUD INSIGHTS

FRAUD READINESS · COMPREHENSIVE

Fraud Readiness Strategy and Control Blueprint

Marula Retail Holdings (Pty) Ltd (fictional)

Assessment reference MKFRS-2026-RV05BD5748

13 November 2026

Confidential. Prepared for the management of Marula Retail Holdings (Pty) Ltd (fictional).

RESTRICTED TEST · Fictional organisation entered through the test deployment · Revised method not approved by MK: no readiness score is issued · Not for customer release

EXECUTIVE DIAGNOSIS

Reported core controls provide a foundation, while unsettled answers and weaker practices require management action

The executive diagnosis shows a reported control foundation that needs clarification and reinforcement

Marula Retail Holdings (Pty) Ltd reports that controls are in place for 86 of the 90 fraud scenarios that apply to its operations. No applicable scenario has a core control reported as a gap. This gives management a reported base from which to strengthen the practices that support those controls and to settle the answers that are not yet clear enough to rely on.

No score, maturity level or readiness conclusion is issued in this report. The revised scoring approach has not been approved, and the organisation should therefore use this assessment as a practical account of its own answers, the operating questions those answers raise and the control designs that can address them.

The organisation's answers include 4 scenarios that require attention before the associated controls are treated as covering the relevant fraud scenarios. These comprise 1 scenario where the answers cannot both be right and 3 scenarios where the answers leave a question unresolved. The controls concerned may operate as intended, but the current answers do not establish that position.

The wider pattern is that controls reported as present sometimes depend on related practices reported as weaker, partly in place or not yet operating. This pattern appears across the assessment and is especially visible in fraud risk assessment, where the answers do not yet provide a sufficiently clear account of how fraud risks are identified, owned, refreshed and acted upon.

The controls this report sets out first begin by settling the inconsistent and incomplete answers. They then strengthen management ownership of fraud risk assessment, bring process knowledge into the assessment, describe risks as practical schemes and establish an approval separation for new suppliers. These actions connect governance, procurement, finance, payroll and operational processes rather than treating fraud risk as a separate compliance exercise.

The reported environment also has areas of stability. Fraud governance and accountability, ethics and anti-corruption, finance and financial reporting, customer and revenue processes, assets and inventory, digital fraud controls, and detection and response are

reported with their core controls in place. The next step is to make the supporting practices as dependable as the core controls that management reports.

WHAT THE ASSESSMENT ESTABLISHES

SCORE

Not issued

The arithmetic result of the answers under the method's scoring frame, shown for traceability. It carries no band.

UNRESOLVED INCONSISTENCIES

1 to settle; 3 to clarify

1 scenario has answers that cannot both be right. A further 3 scenarios raise questions the answers do not settle. Until they are settled, the controls concerned are not treated as covering their scenarios.

PROVISIONAL MANAGEMENT INTERPRETATION

0 with a control reported as a gap

On its own answers, the organisation reports the core control in place for 86 of the 90 fraud scenarios that apply; 4 more have answers to settle or clarify; and 0 have a core control reported as a gap.

APPROVED READINESS CONCLUSION

None issued

MK states its readiness conclusion here under its approved readiness method. Until then the report sets out what the answers establish.

The four statements are kept separate: the calculated result is arithmetic, the inconsistencies and the interpretation come from the organisation's own answers, and the readiness conclusion is MK's.

SCOPE AND ANALYTICAL BASIS

This assessment interprets the organisation's answers and does not provide an external control opinion

The analytical basis identifies relationships between answers rather than control performance

This assessment reads the organisation's answers to the fraud scenarios that apply to its operations and compares answers where the reviewed relationship table indicates that they should align. The comparison covers 50 answer relationships and identifies where answers agree, conflict or depend on a related practice that is described as weaker.

The boundary is the organisation's own answers. MK has not reviewed documents, spoken to staff, observed processes or checked controls in operation. The findings therefore explain what the answers indicate and what management should establish within its processes before relying on the controls concerned.

The report provides strategic interpretation and practical control design. It identifies plausible ways in which a weakness could be exploited, describes the records and checks management should maintain, and sets out leadership choices for ownership, sequencing and oversight. It does not state that a control works in practice or that the organisation has met any legal, regulatory or readiness threshold.

READINESS PROFILE

The reported environment is broadly held, while selected areas show mixed answers that need operating detail

The assessed areas show no reported core-control gaps but uneven supporting practices

Across ten assessed areas, 7 areas are reported with every core control in place. No area is described as having most core controls reported as gaps. The profile is consequently not a picture of absent headline controls; it is a picture of controls whose supporting practices and explanatory answers need to become more consistent.

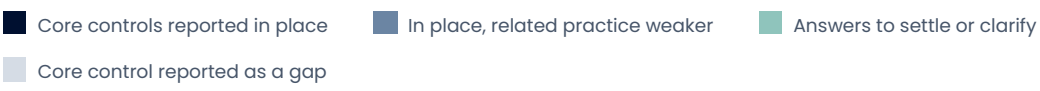
Fraud governance and accountability is reported without a core-control gap, as are ethics and anti-corruption, finance and financial reporting, customers and revenue, assets and inventory, digital fraud controls, and detection and response. These areas provide a reported framework for accountability, operational checks and escalation, subject to management maintaining the related practices that make those arrangements dependable.

Fraud risk assessment, third parties and supply chain, and people, payroll and insider risk show mixed answers. In these areas, the organisation reports core controls in place while also reporting weaker related practices or unresolved questions. That combination does not mean the controls are absent, but it does mean management needs clearer operating accounts of how the controls reach the relevant processes and people.

The profile should guide management towards an integrated programme. Fraud risk assessment should identify and describe the schemes that matter to the organisation's processes. Procurement, finance and payroll should then maintain checks that make it difficult for an individual to initiate, approve and conceal a transaction without another person seeing the underlying evidence.

READINESS PROFILE: FRAUD SCENARIOS BY AREA

AREA	SCENARIOS THAT APPLY	CORE CONTROLS IN PLACE TEST FIGURE
Fraud governance and accountability		13 of 13
Fraud risk assessment		4 of 6
Ethics, integrity and anti-corruption		11 of 11
Third parties and supply chain		10 of 11
People, payroll and insider risk		7 of 8
Finance, banking and financial reporting		10 of 10
Customers, revenue and products		7 of 7
Assets, cash and inventory		4 of 4
Digital, cyber-enabled and identity fraud		12 of 12
Detection, speak-up and response		8 of 8



Each bar shows the fraud scenarios in the method that apply to the organisation in that area, by what its answers report about the controls that stop them. Areas appear in the method's order. Test figures are the calculated result for each area, shown for traceability; they are not scores and carry no band.

SYSTEMIC THEMES

Weaker related practices and incomplete fraud-risk assessment methods can combine to leave controls less dependable than reported

ACROSS THE ORGANISATION

Controls reported as present depend on related practices that need strengthening

The organisation reports 15 scenarios where a core control is in place but a related practice is weaker. Such practices may include incomplete ownership, a process that has been agreed but is not yet operating, a missing separation of duties or an operating step that is applied inconsistently. The result can be a control that appears complete in policy while being less dependable in day-to-day work.

This theme crosses the assessed environment. It can affect how fraud risk is identified, how supplier details are approved, how invoices are matched to evidence of delivery, and how sensitive roles are covered during leave. The common issue is that the headline control may be present, while the activity that gives it practical reach is weaker or unclear.

Management should respond by defining the operating activity, the person responsible, the record retained and the response when the requirement is not met. A control is more likely to remain dependable where it produces a clear record, exceptions are visible to an accountable owner and another person can check that the activity was completed as required.

FRAUD RISK ASSESSMENT

Fraud risk assessment needs a fuller account of how risks are identified, owned and refreshed

Fraud risk assessment is the area where the answers require the greatest clarification and strengthening. 4 of the 6 applicable scenarios in that area involve unsettled answers, questions to clarify or weaker related practices. This does not establish that the assessment is ineffective, but it does show that management needs a clearer account of its design and operation.

An assessment becomes useful when it captures how fraud could occur in a real process, assigns ownership for the response and is refreshed when the organisation changes. Without process owners taking part, risks can remain broad labels rather than practical

schemes. Without walkthroughs, the assessment can miss the points at which money, stock, customer information or supplier data can be manipulated.

The related themes should be treated together. A stronger assessment will identify the operational conditions that make invoice manipulation, supplier creation, artificial identity and insider concealment possible. The process controls then provide the preventative activity, records and escalation that convert the assessment into routine management practice.

WHERE EACH THEME APPEARS

AREA	Controls reported in place rest on weaker practices than the answers suggest	The answers on fraud risk assessment do not yet support the position they report
Fraud governance and accountability	●	
Fraud risk assessment	●	●
Ethics, integrity and anti-corruption	●	
Third parties and supply chain	●	
People, payroll and insider risk	●	
Finance, banking and financial reporting	●	
Customers, revenue and products	●	
Assets, cash and inventory	●	
Digital, cyber-enabled and identity fraud	●	
Detection, speak-up and response	●	

A mark shows an area in which the answers contribute to the theme.

FINDINGS

The selected findings show where clarification and control design will make the reported environment more dependable

FRAUD RISK ASSESSMENT

AI-enabled fraud may not be consistently considered in relevant processes

The answers about AI-enabled fraud cannot both be right as given. The organisation reports that AI-enabled schemes are assessed for relevant processes, while another answer states that high-risk processes do not ask how AI could be used against the controls within them. The fraud risk lead should settle this point before management relies on the reported coverage.

A deepfake instruction, synthetic identity or generated document can defeat a control that depends mainly on recognition of a person, voice, signature or document. In that situation, the control may appear to have been followed because the false input resembles an expected input. The weakness is not necessarily a failure to perform the check, but a failure to recognise that the check can be deceived.

Good practice is to ask, for relevant high-risk processes, how AI could imitate the evidence on which a control relies. Management should then consider whether a separate known channel, a second person or a non-recognition-based check is needed before an instruction, approval or identity is accepted. The assessment should capture any resulting actions and owners.

POSITION	CORE CONTROL	OWNER	FIRST RESPONSE
Answers that cannot both be right	AI-enabled fraud covered: in place	Fraud risk lead	30 days (proposed)

FRAUD RISK ASSESSMENT

The basis for deciding responses to risks above tolerance is not yet clear

The organisation reports that a response is decided where a risk is above tolerance, while also reporting that likelihood and harm ratings are not in place. A risk can be identified as above tolerance without a conventional rating scale, but the answers do not explain the basis used to make that decision. This question should be answered in writing by the fraud risk lead.

Without a clear basis for identifying risks that require a response, management may find it difficult to explain why a control change, process change, insurance decision or acceptance decision was made. Different owners could use different assumptions, and the connection between the fraud assessment and operational action could become unclear.

A practical response is to set out the factors used when a response is required, whether or not formal likelihood and harm ratings are adopted. The method should show how the organisation considers the process affected, the opportunity for funds or stock to leave, the scale of activity and relevant information known to management. That explanation should accompany the assessment outcome.

POSITION	CORE CONTROL	OWNER	FIRST RESPONSE
A question the answers leave open	Response decided: in place	Fraud risk lead	30 days (proposed)

THIRD PARTIES AND SUPPLY CHAIN

Invoice controls need clearer evidence that goods and services were received

The organisation reports that invoices are checked against an approved order and confirmation of receipt before payment. It also reports that receipt of goods is only partly in place and that confirmation of services by the recipient is set out but not yet operating. The unanswered question is what confirmation the invoice check relies on where receipt is not documented.

A supplier could submit an invoice for an inflated rate, fictitious delivery or service that was not performed. If the approver did not receive the goods or service and no reliable receiving evidence is held, payment may proceed through the ordinary payment run. The approval trail can then make the invoice appear properly processed even though the underlying delivery was not established.

The finance lead should define who confirms receipt, what record is required and how service delivery is evidenced before payment. The control should match every invoice to what was approved and to either a documented receipt or a documented service confirmation from the person who received the work. Exceptions should remain visible for review.

POSITION	CORE CONTROL	OWNER	FIRST RESPONSE
A question the answers leave open	Three-way match: in place	Finance lead	30 days (proposed)

PEOPLE, PAYROLL AND INSIDER RISK

Block leave cannot be relied on fully until sensitive roles are identified consistently

Block leave is reported as required for people in sensitive roles, while the maintained list of high-risk roles is only partly in place. The requirement may reach all relevant people through another mechanism, but the organisation's answers do not explain how management confirms that every sensitive role is included.

An employee who remains continuously present in a sensitive role can conceal manipulation by controlling the normal processing, the explanation of unusual items and the response to queries. Where nobody else performs the work for a sustained period, unusual transactions or unexplained adjustments may remain unnoticed because there is no meaningful handover.

The HR and payroll lead should establish how sensitive roles are identified and maintain that information so the leave requirement reaches the correct population. During the absence, another person should perform or review the work, and any irregularity should be brought to the attention of the accountable process owner before normal access is restored.

POSITION	CORE CONTROL	OWNER	FIRST RESPONSE
A question the answers leave open	Block leave required: in place	HR and payroll lead	30 days (proposed)

FRAUD RISK ASSESSMENT

Fraud risk assessment needs management ownership and practical process input

The organisation reports that it has completed a dedicated fraud risk assessment. Related practices are weaker: management ownership is partly in place, process owner participation is not in place, risk descriptions as schemes are partly in place, and process walkthroughs are set out but not yet operating. Together, these conditions can limit how fully the assessment reflects the organisation's actual operations.

A fraud assessment is less useful where risks are expressed only as broad labels. A description such as theft or fraud does not show who could act, what process they could exploit, what record could be changed or which control should interrupt the scheme. Input from the people who run the process is needed to identify those practical opportunities.

The chief executive should require formal management acceptance of the assessment and agreement by the owner of every significant risk. The fraud risk lead should bring process owners into workshops or interviews, describe each risk as a scheme and capture walkthrough notes for relevant processes. These steps make the assessment a working management tool rather than a static document.

POSITION	CORE CONTROL	OWNER	FIRST RESPONSE
Core control in place; related practice weaker	Fraud risks assessed: in place	Fraud risk lead	90 days (proposed)

THIRD PARTIES AND SUPPLY CHAIN

Supplier onboarding needs an approval separation before suppliers become active

The organisation reports a new supplier process that is monitored for compliance and exceptions. It also reports that approval by another person is not in place, director identification is partly in place, comparison of directors with staff is set out but not yet operating, supplier re-checks are set out but not yet operating, and dormant suppliers are not deactivated.

A fictitious or shell supplier could be created where the person entering supplier details can also cause the supplier to become active without another person reviewing the entry. Invoices may then enter normal processing under a supplier name that appears legitimate. Weak director checks and inactive supplier records can make the opportunity harder to identify.

The chief financial officer should require that a new supplier becomes active only after approval by someone other than the person who captured it. The supplier approval log should show both people and the approval timing. Procurement should also progress the related practices concerning director information, comparison with staff, supplier refreshes and deactivation of dormant suppliers.

POSITION	CORE CONTROL	OWNER	FIRST RESPONSE
Core control in place; related practice weaker	New supplier process: in place	Procurement lead	In the twelve-month programme

FRAUD RISK ASSESSMENT

Fraud risk assessment can fall out of date when change is not supported by records and owner awareness

The organisation reports that change projects include a fraud risk step by default and that the assessment owner confirms completion of updates. At the same time, the assessment itself is reported as not documented and owners are reported as not knowing their risks. Those conditions can make updates difficult to trace and harder for process owners to apply.

Business change can introduce new products, structures, suppliers, customer channels or technology. If the assessment is not documented and owners do not understand the risks assigned to them, the update may become informal. A change can then proceed without a clear account of how fraud could occur or whether existing controls still address the changed process.

The fraud risk lead should maintain an accessible assessment record and ensure that owners receive and acknowledge the risks relevant to their processes. Change activity should include an explicit fraud-risk consideration, with completion retained alongside the change information. Management acceptance of significant risks will help ensure that updates result in accountable action.

POSITION	CORE CONTROL	OWNER	FIRST RESPONSE
Core control in place; related practice weaker	Updated when the business changes: in place	Fraud risk lead	In the twelve-month programme

Plausible fraud pathways show how operational gaps can combine into continuing loss and concealment

FRAUD PATHWAY · THIRD PARTIES AND SUPPLY CHAIN

Invoices may be paid for deliveries or services that cannot be supported by receiving evidence

A supplier may inflate billing, submit an invoice for goods not received or claim for a service not performed. The invoice can enter ordinary processing with an approval from a person who did not receive the goods or service. Where the approval is accepted as sufficient evidence, payment can proceed without a reliable connection to what the organisation actually received.

The pathway relies on inconsistent receiving evidence. Goods may not have a documented receipt before payment, and services may not be confirmed by the person who received them. Overbilling can be concealed among ordinary supplier invoices because the invoice has passed through an approval route even though the approval did not establish delivery.

Where a concern arises, payment on the affected invoices should be held, the invoices reconciled to orders and receiving information, and the approval trail retained. The enduring response is to require a match to approved purchasing information and documented receiving evidence or service confirmation before payment is released.

WARNING SIGNS

- Invoices without a matching receipt or delivery note
- Rates above the agreed contract
- Service invoices approved by people far from the work
- One approver for a supplier's invoices over a long period

FIRST RESPONSE

Hold payment on the suspect invoices, reconcile them to orders and receipts, and preserve the approval trail.

LASTING CONTROL

Every invoice is matched to an approved order and a recorded receipt or confirmed service before payment.

FRAUD PATHWAY · FRAUD RISK ASSESSMENT

AI-generated impersonation can defeat controls built only around recognition

An outsider may use AI tools to imitate a known person, create a synthetic identity or produce a convincing document. The false instruction or identity can enter through normal channels and appear credible to a person performing a recognition-based control. A payment, account, approval or access decision could then be made on false grounds.

The pathway relies on the assessment not asking how AI could be used against controls in relevant high-risk processes. A voice, image, signature or document may appear familiar even where it is artificial. The control can appear to have been followed, which makes the weakness difficult to see from the ordinary process record alone.

Suspect instructions or documents should be confirmed through a separate known channel, and the organisation should avoid reliance on recognition-only checks in the affected process. The long-term response is to include AI-enabled misuse in the fraud assessment and redesign controls where recognition is the sole basis for acceptance.

WARNING SIGNS

- Requests that rely only on recognising a person or document
- Documents with flawless formatting from new counterparties
- Video or voice contact that avoids interaction
- Identity details that fit together too neatly

FIRST RESPONSE

Confirm the instruction or document with its source through a separate known channel, and suspend reliance on recognition-only checks in the process concerned.

LASTING CONTROL

The fraud risk assessment asks, for each high-risk process, how AI could be used against its controls, and controls that rely on recognition are tested and redesigned.

FRAUD PATHWAY · PEOPLE, PAYROLL AND INSIDER RISK

Continuous control of a sensitive role can allow an insider to conceal manipulation

A trusted employee in a sensitive role may manipulate the records within their ordinary daily work and remain available to explain any question that could expose the activity. The opportunity arises where that person does not take sustained leave and no other person performs or reviews the work during an absence.

The pathway relies on a sensitive role not being consistently identified and on the leave requirement therefore not reaching the people who need it. Continuous presence can conceal a scheme that requires regular adjustment or intervention. Resistance to leave, rotation or process change can be a warning indicator requiring management attention.

Where a concern arises, the work should be placed with another person, transactions for the relevant period should be reviewed and records should be retained before the employee is approached. The sustained response is to maintain sensitive-role information and require block leave during which another person performs or reviews the work.

WARNING SIGNS

- An employee in a sensitive role who does not take leave
- Work that only one person understands or is allowed to do
- Queries that are always routed to the same person
- Resistance to rotation or process change

FIRST RESPONSE

Place the work with someone else immediately, review the period's transactions, and preserve the records before the employee is approached.

LASTING CONTROL

Sensitive roles are identified and recorded, and everyone in them takes block leave each year during which someone else does their work.

TARGET FRAUD-CONTROL ENVIRONMENT

The target control environment connects management ownership, process insight and supplier approval separation

CONTROL BLUEPRINT · TO STRENGTHEN

Management acceptance makes fraud-risk ownership explicit

Management currently receives assessment results, but the target arrangement requires formal acceptance and agreement by the owner of every significant risk. This gives the organisation a clear point at which senior management accepts the assessment output and takes responsibility for the actions that follow.

The fraud risk lead should present the assessment for acceptance, document the meeting at which it was accepted and retain the agreement of the relevant risk owner. Any incomplete element should become an open item with an owner and be completed before the assessment is relied upon. A periodic review should sample the acceptance information and report exceptions.

FRAUD SCENARIO IT ADDRESSES
Fraud risks are never identified

ACCOUNTABLE EXECUTIVE
Chief executive

PROCESS OWNER
Fraud risk lead

POPULATION
Significant risks

FREQUENCY
after each assessment

SERVICE LEVEL (PROPOSED)
Completed each time, before the result is relied on; exceptions answered within the month.

INDEPENDENT CHECK
A periodic review by the fraud risk lead, who samples the records and reports exceptions.

RECORD KEPT
Assessment acceptance record: the meeting that accepted the assessment, each significant risk's owner and their agreement.

EFFECTIVENESS MEASURE
The assessment current at the end of the period shows formal acceptance by management and an agreed owner for every significant risk.

ESCALATION
Any case handled without the check, or any exception approved, is reported to the chief executive within the month.

FAILURE RESPONSE
Record any part of the assessment that does not meet the requirement as an open item with an owner, and complete it before the next sign-off.

CONNECTED CONTROLS
Process owners take part; Risks described as schemes; Processes walked through

CONTROL BLUEPRINT · TO STRENGTHEN

Process-owner participation brings operational knowledge into fraud-risk assessment

Process owners are reported as not taking part in the assessment. The target arrangement requires the people who run relevant high-risk processes to participate through workshops or interviews, with their contribution documented. Their involvement is important because they understand the hand-offs, workarounds, records and approval points that create opportunity.

The fraud risk lead should maintain participation information for each relevant process, identify omissions as open items and obtain completion before assessment sign-off. The control should be applied whenever the assessment is refreshed, beginning with processes that move money or stock. Management can then see who contributed practical process knowledge to the assessment.

FRAUD SCENARIO IT ADDRESSES

Fraud risks are never identified

ACCOUNTABLE EXECUTIVE

Chief executive

PROCESS OWNER

Fraud risk lead

POPULATION

High-risk processes

FREQUENCY

at each assessment

SERVICE LEVEL (PROPOSED)

Completed each time, before the result is relied on; exceptions answered within the month.

INDEPENDENT CHECK

A periodic review by the fraud risk lead, who samples the records and reports exceptions.

RECORD KEPT

Assessment participation record: for each high-risk process, who took part and how.

EFFECTIVENESS MEASURE

The assessment current at the end of the period shows participation by the people who run every high-risk process.

ESCALATION

Any case handled without the check, or any exception approved, is reported to the chief executive within the month.

FAILURE RESPONSE

Record any part of the assessment that does not meet the requirement as an open item with an owner, and complete it before the next sign-off.

CONNECTED CONTROLS

Management owns the results; Risks described as schemes; Processes walked through

CONTROL BLUEPRINT · TO STRENGTHEN

Specific scheme descriptions make fraud risks actionable

The target arrangement requires every fraud risk to be described as a practical scheme that states who could commit it, how it could happen and which process could be affected. This moves the assessment away from broad labels and creates a direct connection between the fraud opportunity and the control needed to interrupt it.

The fraud risk lead should maintain a register containing the perpetrator, method and affected process for every risk. Exceptions should be assigned to an owner and resolved before sign-off. A periodic sampling review should identify incomplete descriptions, and management should require correction where a broad label does not provide enough information to design a practical response.

FRAUD SCENARIO IT ADDRESSES

Fraud risks are never identified

ACCOUNTABLE EXECUTIVE	PROCESS OWNER	POPULATION
Chief executive	Fraud risk lead	Risks
FREQUENCY	**SERVICE LEVEL (PROPOSED)**	**INDEPENDENT CHECK**
at each assessment and update	Completed each time, before the result is relied on; exceptions answered within the month.	A periodic review by the fraud risk lead, who samples the records and reports exceptions.

RECORD KEPT

Fraud risk register: for each risk, the perpetrator, the method and the process affected.

EFFECTIVENESS MEASURE

The assessment current at the end of the period shows every risk described with its perpetrator, method and process.

ESCALATION

Any case handled without the check, or any exception approved, is reported to the chief executive within the month.

FAILURE RESPONSE

Record any part of the assessment that does not meet the requirement as an open item with an owner, and complete it before the next sign-off.

CONNECTED CONTROLS

Management owns the results; Process owners take part; Processes walked through

CONTROL BLUEPRINT · TO STRENGTHEN

Process walkthroughs identify fraud opportunities at the point they arise

The organisation reports that process walkthroughs are agreed but not yet operating. The target arrangement requires relevant processes to be considered step by step with the people who run them, identifying where an actor could alter information, bypass an approval, create a false record or conceal an irregular transaction.

Walkthrough notes should identify the process steps considered, the people who contributed and the opportunities found. The fraud risk lead should review the notes periodically, assign any incomplete work as an open item and require completion before the assessment is relied upon. This should begin with payment, payroll and procurement processes.

FRAUD SCENARIO IT ADDRESSES
Fraud risks are never identified

ACCOUNTABLE EXECUTIVE
Chief executive

PROCESS OWNER
Fraud risk lead

POPULATION
High-risk processes

FREQUENCY
at each assessment

SERVICE LEVEL (PROPOSED)
Completed each time, before the result is relied on; exceptions answered within the month.

INDEPENDENT CHECK
A periodic review by the fraud risk lead, who samples the records and reports exceptions.

RECORD KEPT
Process walkthrough notes: for each high-risk process, the steps reviewed, who took part and the fraud opportunities found.

EFFECTIVENESS MEASURE
The assessment current at the end of the period shows a recorded walkthrough for every high-risk process.

ESCALATION
Any case handled without the check, or any exception approved, is reported to the chief executive within the month.

FAILURE RESPONSE
Record any part of the assessment that does not meet the requirement as an open item with an owner, and complete it before the next sign-off.

CONNECTED CONTROLS
Management owns the results; Process owners take part; Risks described as schemes

CONTROL BLUEPRINT · TO STRENGTHEN

Independent approval prevents a supplier from becoming active through a single person's action

The target supplier control requires a person other than the person who captured the supplier to approve the supplier before activation. This separation makes it harder for an individual to create and activate a fictitious supplier without another person seeing the supplier information and approving the entry.

Procurement should maintain an approval log showing who captured the supplier, who approved it and when approval occurred. Where a supplier was approved by the person who processed it, the supplier should be approved independently and the person's other supplier entries should be reviewed for the relevant period. The chief financial officer should receive exceptions through routine reporting.

FRAUD SCENARIO IT ADDRESSES
A fictitious supplier is created and paid

ACCOUNTABLE EXECUTIVE
Chief financial officer

PROCESS OWNER
Procurement lead

POPULATION
New suppliers

FREQUENCY
before each new supplier becomes active

SERVICE LEVEL (PROPOSED)
Completed before each new supplier becomes active; nothing proceeds while the check is open.

INDEPENDENT CHECK
Built into the control: the check is carried out by someone independent of the person whose work it covers.

RECORD KEPT
Supplier approval log: who captured each supplier, who approved it and when.

EFFECTIVENESS MEASURE
Every new supplier in the period was approved by someone other than the person who processed it, before it became active.

ESCALATION
Any item that proceeds without the check, or any exception approved, is reported to the chief financial officer within the month.

FAILURE RESPONSE
Have any new supplier approved by the person who processed it re-approved independently, and review that person's other new suppliers for the period.

CONNECTED CONTROLS
Directors identified; Directors compared with staff; Suppliers re-checked; Dormant suppliers deactivated

TARGET FRAUD-RISK OPERATING MODEL

Clear accountability connects board oversight, executive direction, process operation and independent investigation

The target operating arrangement assigns responsibility across the fraud-control environment

The board receives fraud-risk reporting, approves the order of work and holds the executive to account. This oversight role is consistent with the organisation's own answer on final oversight and gives the board visibility of open scenarios, blockers and management decisions.

The chief executive is accountable for fraud risk overall, names accountable executives and decides the order of work. This role should ensure that process owners receive the authority and resources required to settle questions, improve controls and respond where a requirement is not being met.

The fraud risk lead coordinates the assessment, challenges control owners and consolidates status reporting. Procurement, finance, and HR and payroll owners operate controls in their processes, retain the necessary records and report exceptions. This arrangement places operational responsibility with the people who can change the process.

The investigations lead receives reports and alerts, investigates independently and retains outcomes. This separation allows concerns to be handled outside the process that may be involved, while the board and chief executive retain visibility of matters requiring resources, decisions or intervention.

TARGET FRAUD-RISK OPERATING MODEL

OVERSIGHT **The board**	Receives fraud risk reporting, approves the order of work and holds the executive to account. The organisation's own answer on final oversight. STATUS AND ESCALATIONS REPORTED UPWARD · DIRECTION AND DECISIONS DOWNWARD
EXECUTIVE ACCOUNTABILITY **Chief executive**	Accountable for fraud risk overall; names the accountable executives and decides the order of work. Executive accountability is reported as "Yes, it is written into a named executive's role".
COORDINATION AND CHALLENGE **Fraud risk lead**	Coordinates the fraud risk assessment, challenges the control owners and consolidates status reporting. The method's owner for fraud risk assessment.
CONTROL OWNERSHIP **Fraud risk lead, Procurement lead, Finance lead and HR and payroll lead**	Operate the controls in their processes, keep the records and report exceptions. The method's owners for the controls this report acts on.
DETECTION AND INVESTIGATION **Investigations lead**	Receives reports and alerts, investigates independently and records outcomes. The method's owner for detection, speak-up and response.

Roles are named by function, not by person; the assessment does not identify individuals. The chief executive's coordinating role and the fraud risk lead's challenge role are the method's owners for governance and risk assessment.

LEADERSHIP DECISIONS

Leadership decisions should settle uncertainty, assign accountability and sustain board visibility

LEADERSHIP DECISION

Controls affected by inconsistent answers should not be relied upon until the answers are settled

The chief executive should require process owners to establish how the affected processes operate, document their answers and correct the assessment where necessary. This is the recommended initial route because the questions concern the organisation's own operating activities and can be addressed by the people responsible for those activities.

Where an answer remains disputed, management can use a walkthrough by a manager outside the process or another internal function able to provide separation from the process owner. A separately scoped external review is also available where management wants an outside view of process operation. These routes require more time and effort but provide greater separation from the original answer.

The recommended route is for process owners to confirm and correct, with an internal walkthrough where the issue remains unresolved. This enables prompt clarification while recognising that a control should not be treated as covering a scenario if the organisation cannot establish how the process actually operates.

OPTION	WHAT IT INVOLVES	EFFORT	BENEFIT	TRADE-OFF
Process owners confirm and correct	Each process owner establishes how the process actually runs, records the answer and corrects the assessment where it was wrong.	Low: a few hours per process owner.	Fast, and keeps ownership with the people who run the processes.	Relies on the same people whose answers are in question.
Internal walkthrough by someone independent of the process	A manager from another area, or internal audit where it exists, walks through each process with its owner and records what was seen.	Moderate: a day or two per process.	An answer that does not rest only on the owner's view.	Takes longer and draws on people outside the process.

OPTION	WHAT IT INVOLVES	EFFORT	BENEFIT	TRADE-OFF
Independent validation through MK Advisory	MK examines the records and walks through the processes concerned, as a separately scoped engagement.	Higher: a scoped engagement.	An independent view of whether the controls operate, which the automated assessment cannot give.	Cost and time; worthwhile where the answers concern controls the organisation relies on heavily.

MK'S RECOMMENDED ROUTE

Process owners confirm and correct, with an independent walkthrough for any answer that is still disputed. The answers concern how the organisation's own processes run, which its owners can establish quickly; an independent view is needed only where that does not settle the question.

Decision owner: Chief executive. When: Before the controls concerned are relied on or reported as in place. If delayed: The organisation may rely on a control whose operation the answers do not establish.

LEADERSHIP DECISION

Outstanding questions need named ownership or a documented open item

The organisation has 1 outstanding question held by 1 function. The chief executive should assign it to a named person for an answer or require it to be retained as an open item with an owner. This ensures that incomplete information remains visible rather than being assumed away.

Management may either assign the question directly, proceed with a documented open item or establish the answer by inspecting the relevant process. The recommended route is to assign the question and retain any unanswered matter as an open item. This preserves programme momentum while ensuring that the scenario affected remains clearly identified as unresolved.

OPTION	WHAT IT INVOLVES	EFFORT	BENEFIT	TRADE-OFF
Assign each question to a named person	Each outstanding question is assigned to one named person with a date for an answer.	Low.	Closes most gaps quickly and shows who holds the knowledge.	Some questions may reveal that nobody holds the answer, which is itself a finding.
Record as open items and proceed	Questions that cannot be answered are recorded as open items with an owner, and the work proceeds on what is known.	Low.	The programme is not delayed.	Decisions on the scenarios affected rest on incomplete information.

OPTION	WHAT IT INVOLVES	EFFORT	BENEFIT	TRADE-OFF
Establish the answer by inspecting the process	Where nobody holds the answer, the owner inspects the process and records what is found.	Moderate.	Converts an unknown into a fact.	Time from people who run the process.

MK'S RECOMMENDED ROUTE

Assign each question to a named person, and record any that cannot be answered as an open item. An answer, or a recorded open item with an owner, is what allows the scenarios the questions affect to be decided.

Decision owner: Chief executive. When: Before the scenarios they affect are ordered. If delayed: The scenarios they affect stay unknown rather than covered.

LEADERSHIP DECISION

Open scenarios need accountable executives and coordinated process ownership

The chief executive should name an accountable executive for the area with unresolved fraud-risk assessment scenarios before design work begins. The accountable executive should have authority over the relevant process, system and people, while the fraud risk lead coordinates requirements that span more than one operating area.

Leadership may place responsibility with area executives, concentrate ownership in a single executive or use area ownership supported by a programme coordinator. The recommended route keeps ownership in the operating areas and gives the fraud risk lead a coordinating role. This balances local responsibility with consistent design of shared requirements.

OPTION	WHAT IT INVOLVES	EFFORT	BENEFIT	TRADE-OFF
One accountable executive per area	Each area with open scenarios has one executive accountable for its controls, as the method suggests.	Low to decide; ongoing for each executive.	Clear ownership that matches how the organisation is run.	Requirements that span areas, such as how changes to payment details are verified, need coordination across owners.
One executive for the whole programme	A single executive owns every open scenario and directs area leads.	Concentrated on one person.	One point of accountability and a consistent approach.	Area executives may treat the work as someone else's.
Area owners with a programme coordinator	Area executives own their scenarios, and the fraud risk lead coordinates requirements that span areas and reports progress.	Moderate.	Ownership stays in the areas while cross-area requirements are handled once.	Needs a coordinator with enough standing to hold owners to account.

MK'S RECOMMENDED ROUTE

Area owners with a programme coordinator. The open scenarios sit in the operating areas, so ownership belongs there; several of the requirements span areas and are best designed once.

Decision owner: Chief executive. When: Before design work starts. If delayed: Open scenarios have no owner, and the controls that stop them stay unassigned.

LEADERSHIP DECISION

The order of work should use explicit factors after answers are settled

The order of work should not be inferred from the order in which findings appear in this report. MK has not approved a method for ranking fraud risks. Leadership should instead use explicit factors after unsettled answers have been addressed, including whether money, pay, cash or stock can leave without a control and what management knows about the activity affected.

Management may work area by area, address cross-area requirements before area-specific work, or use explicit factors while applying shared requirements once where they arise. The recommended route uses explicit factors and settled facts, with shared requirements designed once. This creates an order that the board can understand and management can explain.

OPTION	WHAT IT INVOLVES	EFFORT	BENEFIT	TRADE-OFF
Explicit factors, settled facts first	Answers to settle come first; then each open scenario is weighed on how far its control is reported in place, whether money, pay, cash or stock can leave without it, how much of the activity exists, and what management already knows of incidents.	Moderate: a structured management session.	A defensible order that management can explain to the oversight body.	Depends on information management must supply, such as volumes and known incidents.
Area by area	One area is completed before the next begins.	Low to plan.	Simple to manage and report.	Requirements that span areas are designed several times, and exposure in later areas waits.
Cross-area requirements first	Requirements that span areas, such as verifying changes to payment details, are designed once and applied everywhere, before area-specific controls.	Moderate.	One design closes several scenarios at once.	Area-specific exposures wait until the shared designs are complete.

MK'S RECOMMENDED ROUTE

Explicit factors, settled facts first, applying cross-area requirements once where they arise. An order of work should rest on facts management can state and defend to its oversight body, and designing shared requirements once avoids building the same control several times.

Decision owner: Chief executive. When: Before design work starts. If delayed: Effort is spread across every scenario at once, or follows the order of this report, which is not a ranking.

LEADERSHIP DECISION

Board reporting at every meeting will keep unresolved scenarios visible

The board should receive a concise status for every open scenario at each meeting until the scenario is closed, deferred with a reason or accepted. The status should identify the owner, the action underway, any blocker and the decision required from leadership.

Less frequent consolidated reporting reduces the immediate reporting burden, while exception-only reporting can omit progress that is slow but not formally late. The recommended route keeps the scenarios visible at every board meeting so that blockers can be removed and management accountability remains active.

OPTION	WHAT IT INVOLVES	EFFORT	BENEFIT	TRADE-OFF
At each meeting of the oversight body	A one-page status per open scenario at each meeting until it is closed, deferred with a reason or accepted.	Low.	Keeps the scenarios visible to the people who can remove blockers.	Adds to the oversight body's agenda.
Quarterly summary	A consolidated summary each quarter.	Low.	Less frequent demand on the oversight body.	Blockers may wait a quarter before they are seen.
Exceptions only	Only scenarios that are late or blocked are reported.	Lowest.	Focuses attention on problems.	The oversight body does not see progress, and a scenario can drift without being reported as an exception.

MK'S RECOMMENDED ROUTE

At each meeting of the oversight body, until each open scenario is closed, deferred with a reason or accepted. Regular reporting is what keeps a programme moving once the first controls are in place.

Decision owner: Chief executive. When: From the first meeting after this report. If delayed: Progress is not visible until the next assessment.

The proposed programme moves from clarification to operating controls and sustained measurement

The proposed stages create a practical route from unsettled answers to embedded control operation

The proposed stabilisation stage focuses on settling inconsistent answers, answering open questions, naming accountable executives and agreeing the order of work. These actions provide the factual and governance base for later design activity. The fraud risk lead, finance lead, HR and payroll lead, procurement lead and chief executive all have roles in this stage.

The proposed establishment stage puts the selected control designs into operation. Management acceptance of assessment results, process-owner participation, scheme descriptions, walkthroughs and independent supplier approval should be approved, implemented and taken through an initial operating cycle. The fraud risk lead and procurement lead are central to this work.

The proposed embedding stage extends work to the remaining selected scenarios and strengthens related practices across the organisation. Regular status reporting should become part of management activity, and process owners should address the supporting practices that allow controls to operate consistently rather than only on paper.

The proposed maturity stage focuses on measuring controls over a full operating cycle, refreshing scenarios against the assessment and reporting status to the board at each meeting. This stage is intended to make fraud-risk management a continuing management activity that responds to business change rather than a once-off assessment exercise.

THE TWELVE-MONTH PROGRAMME, IN PROPOSED STAGES

Stabilise

0 TO 30 DAYS, PROPOSED

Settle the answers, name the owners and decide the order of work.

- Answers settled and questions answered
- Outstanding questions answered or owned
- Accountable executives named
- Order of work recorded with its factors

OWNERS

Fraud risk lead, Finance lead, HR and payroll lead, Procurement lead, Chief executive

Establish

31 TO 90 DAYS, PROPOSED

Approve the priority control designs, put them in place and run their first operating cycles.

- Management owns the results
- Process owners take part
- Risks described as schemes
- Processes walked through
- New supplier approved by another person

OWNERS

Fraud risk lead, Procurement lead

Embed

MONTHS 4 TO 6, PROPOSED

Extend to the remaining selected scenarios and strengthen the further defences, with regular reporting.

- Remaining selected controls put in place
- Related practices strengthened
- Monthly status reporting running

OWNERS

Every area owner, coordinated by the fraud risk lead and reporting to the chief executive

Mature

MONTHS 7 TO 12, PROPOSED

Measure each control over a full cycle, refresh the scenarios and report to the oversight body.

- Each control measured over a full cycle
- Scenarios refreshed against the assessment
- Status reported to the board at each meeting

OWNERS

Every area owner, coordinated by the fraud risk lead and reporting to the chief executive

Windows are proposals for management's own plan. They are not deadlines, contractual dates or estimates of how long any control takes to design, put in place or show to be working. Every action, with its deliverable and completion test, is in the supporting workbook.

MANAGEMENT FRAUD-READINESS SCORECARD

The scorecard makes ownership, completion and escalation visible to management and the board

Practical measures will show whether the proposed controls are being operated as designed

The fraud risk lead should track whether the current assessment shows formal management acceptance and agreed ownership for every significant risk. Any case handled without that check, or any approved exception, should be reported to the chief executive within the month. This measure connects executive ownership to the assessment output.

The fraud risk lead should also track participation by people who run relevant high-risk processes, scheme descriptions that identify perpetrator, method and process, and walkthrough notes for relevant processes. These measures should be considered whenever the assessment is refreshed or updated, with exceptions escalated to the chief executive.

Procurement should track whether every new supplier was approved by someone other than the person who processed it before activation. Any item that proceeds without the check, or any approved exception, should be reported to the chief financial officer within the month so that corrective action is visible outside the immediate process.

The chief executive should track written answers for matters to settle, responses to outstanding questions and ownership decisions for open scenarios. Items that remain open beyond the stated escalation point should be reported to the board. This allows leadership to distinguish between a question being actively addressed and a question that has simply remained unresolved.

The fraud risk lead should report whether priority controls have met their stated success measures over a full operating cycle. A control that misses its measure repeatedly should be reported with the owner's correction plan. The chief executive should ensure that status reporting reaches the board at each meeting.

MANAGEMENT FRAUD-READINESS SCORECARD

MEASURE	OWNER	FREQUENCY	ESCALATION THRESHOLD
The assessment current at the end of the period shows formal acceptance by management and an agreed owner for every significant risk.	Fraud risk lead	after each assessment	Any case handled without the check, or any exception approved, is reported to the chief executive within the month.
The assessment current at the end of the period shows participation by the people who run every high-risk process.	Fraud risk lead	at each assessment	Any case handled without the check, or any exception approved, is reported to the chief executive within the month.
The assessment current at the end of the period shows every risk described with its perpetrator, method and process.	Fraud risk lead	at each assessment and update	Any case handled without the check, or any exception approved, is reported to the chief executive within the month.
The assessment current at the end of the period shows a recorded walkthrough for every high-risk process.	Fraud risk lead	at each assessment	Any case handled without the check, or any exception approved, is reported to the chief executive within the month.
Every new supplier in the period was approved by someone other than the person who processed it, before it became active.	Procurement lead	before each new supplier becomes active	Any item that proceeds without the check, or any exception approved, is reported to the chief financial officer within the month.

MEASURE	OWNER	FREQUENCY	ESCALATION THRESHOLD
Answers to settle and questions to clarify that have a written answer	Chief executive	each month until closed	Any item still open after the first 30 days is reported to the oversight body.
Outstanding questions answered by the function that holds them	Chief executive	each month until closed	A question still unanswered after 30 days is assigned to a named person and reported.
Open scenarios with a named owner and a recorded decision to address, defer or accept them	Chief executive	each month	A scenario without an owner after 60 days is reported to the oversight body.
Priority controls that have met their success measure for a full operating cycle	Fraud risk lead	each quarter	A control that misses its measure twice is reported with its owner's correction plan.
Status reported to the board	Chief executive	each meeting	A missed report is itself reported at the next meeting.

Control measures describe what each control's records should show for a period once it operates; programme measures track the response itself. None is reported as met today.

METHODOLOGY AND LIMITATIONS

The report provides a management interpretation while readiness and prioritisation methods remain pending approval

Readers should use the report as an advisory assessment of the organisation's answers

This assessment compares the organisation's answers across linked fraud scenarios and identifies contradictions, questions requiring clarification and supporting practices described as weaker. It does not calculate a score, issue a maturity level or draw a readiness conclusion because the relevant approaches await MK approval.

The selection of findings and responses follows the stated selection rules and is not a risk ranking. Management should determine the order of work through explicit leadership decisions based on settled facts and the circumstances of its own operations. The report does not state that any scenario is more important than another.

Control, scenario and decision content remain drafts pending MK approval. Management can nevertheless use the proposed actions, roles, records and measures as practical material for discussion, ownership and implementation planning, subject to its own governance decisions.

MANAGEMENT CONCLUSION

Management can strengthen the reported control foundation by settling answers and embedding practical operating disciplines

The required transition is from reported control presence to consistent, accountable operation

Marula Retail Holdings reports core controls in place for 86 of the 90 applicable fraud scenarios, with 0 scenario reported as having a core-control gap. The immediate management task is to settle the 4 scenarios whose answers are contradictory or incomplete before relying on the affected controls.

The proposed stabilisation stage should leave management with written answers to unsettled matters, named ownership for open scenarios and an agreed order of work. The proposed establishment stage should then produce formal ownership of assessment results, practical input from process owners, scheme-based risk descriptions, walkthroughs and independent supplier approval.

Over the wider programme, success means that controls are operated through clear activities, supported by records, checked by someone with suitable separation from the activity and escalated when requirements are missed. It also means that the fraud assessment is refreshed as the organisation changes and that the board receives clear status information on open scenarios.

The board and chief executive should use the proposed decisions to maintain visibility and remove blockers. The fraud risk lead should coordinate the assessment and reporting activity, while procurement, finance, HR and payroll owners make the relevant process changes. This shared accountability is the route to a control environment that is practical in daily operations.

A separately scoped external review may add value once management has settled its answers and implemented the selected designs, particularly where leadership wants an outside view of how a process operates. Until then, the immediate focus should remain on clarification, accountable ownership, control operation and regular board visibility.

Fraud strategy, readiness and operational resilience.

info@mkfraud.co.za
www.mkfraud.co.za

This report was prepared for the management of Marula Retail Holdings (Pty) Ltd (fictional) on the basis of the organisation's own answers to the MK Fraud Readiness assessment. It is confidential to the organisation. MK Fraud Insights is a trading name of Stonda (Pty) Ltd. Restricted test; not for customer release.